

Risk Assessment Method for 5G-oriented DLMS/COSEM Communications

Alexios Lekidis^{*†} and Elpiniki I. Papageorgiou, Senior Member, IEEE ^{*}

^{*}University of Thessaly, Dpt. of Energy Systems, Gaiopolis Campus, 41500, Larissa, Greece

[†]Public Power Corporation, Chalkokondili 22, 10432, Athens, Greece

Email: ^{*}{alekidis, elpinikipapageorgiou}@uth.gr, [†]a.lekidis@dei.gr

Abstract—The Advanced Metering Infrastructure (AMI) is lately introduced to ensure the real-time exchange of smart meter measurements and their availability for both utilities as well as their customers. DLMS/COSEM is the mostly used protocol for AMI systems as well as allows the integration in 5G-enabled network slices to increase the reliability of energy measurement exchange and availability of sufficient data to calculate energy demand. Nevertheless, such integration augments the threat landscape and increases the probability of cyber-attacks by malicious entities, which aim at the exploitation of vulnerabilities. In this paper, we propose a risk assessment method based on the NIST SP 800-30 standard, for identifying such vulnerabilities as well as to classify them according to a risk matrix based also on their impact on the AMI system. The method is then applied to the DLMS/COSEM, in order to identify its vulnerabilities, which may be later be exploited within a cyber-attack aiming in disruption the AMI system operation. Moreover, it is demonstrated through a 5G-enabled emulated smart home network which is used to exploit smart meter vulnerabilities and then through a lateral movement to conduct attacks causing fluctuations on PhotoVoltaic (PV) systems and energy storage batteries.

I. INTRODUCTION

Smart meters allow the real-time availability of electricity production and consumption data (i.e., current, voltage, active and reactive power) as well as the implementation of automated customer billing scenarios based on their overall consumption. This is achieved through the Advanced Metering Infrastructure (AMI) system [1]. The AMI system includes smart meters deployed 1) in consumer households, 2) near distribution transformers, and 3) near commercial and industrial business consumers (e.g. manufacturing systems providers, hospitals and banks) as well as a central platform for collecting the measurements, called AMI Headend [2]. The Headend is a dedicated software, installed in a server, which can collect smart meter data from different areas, perform validation and pre-processing as well as configuration setup and modification, software updates and ad-hoc requests for the smart meters.

There are multiple protocols involved in AMI system communication. Amongst them DLMS/COSEM is the main protocol used to exchange smart meter measurements over 4G, 5G network. This applies to all the locations from where the data are transmitted from. DLMS/COSEM serves as a extensively employed communication protocol for metering devices [3]. Device Language Message Specification (DLMS) outlines a framework for representing communication entities. On the other hand, the COmpanion Specification for Energy Metering (COSEM) defines the object model in ASN.1 notation for data exchange with smart meters. Furthermore, DLMS/COSEM finds widespread utility in the measurement of energy, gas, heat, and water within commercial/industrial environments.

Through DLMS/COSEM smart meters can also be integrated in 5G networks, to satisfy the requirements specified by the ETSI TS 122 261 standard [4] for the availability of sufficient data allowing utility companies to calculate energy demand. As a shared infrastructure with different network segments though (i.e., Core, Access, Transport, Multi-access edge

computing (MEC)), such integration increases substantially the threat landscape [5]. To ensure cyber-security in an AMI system, first network visibility has to be ensured. Visibility is accomplished through passively real-time monitoring and interpreting the proprietary protocols of the infrastructure. This allows building an industrial asset inventory to ensure full visibility of the AMI architecture. Monitoring covers both physical and cyber system aspects and is followed by a risk assessment procedure based on NIST SP 800-30 [6].

Risk assessment allows predicting the potential dangers and vulnerabilities of the AMI architecture. Accordingly, the risk is evaluated with real metrics for the impact that is caused on the AMI system and the likelihood of cyber-attacks that are discovered through real-time monitoring. This paper presents a method for assessing the risk in DLMS/COSEM communications by identifying the protocol vulnerabilities as well as by assessing the impact in the AMI system. Concretely, it includes the following contributions:

- Risk assessment method to identify the critical points in the AMI system and its integration in 5G network slices.
- Vulnerabilities of the DLMS/COSEM protocol that may lead to risks in an AMI system.
- Application of the method for the exploitation of vulnerabilities in an emulated smart home testbed.

The rest of the paper is organized as follows. Section II provides an overview of the DLMS/COSEM protocol and the smart meter integration in 5G-enabled network slices. Section III provides an overview of the proposed risk assessment method. Then, Section IV illustrates the identified vulnerabilities on DLMS/COSEM that may lead to potential risks. The method is demonstrated in a 5G-enabled smart home network in Section V. Finally, Section VI provides conclusions and some perspectives for future work.

II. BACKGROUND

A. DLMS/COSEM overview

DLMS/COSEM employs a client-server architecture, with the AMI Headend typically acting as the client and the smart meter as the server in standard operational scenarios. Additionally, it supports push mechanisms, allowing the server to transmit information directly to the client. This capability becomes essential, for instance, when dispatching critical alarms for 1) the grid operation and 2) the energy demand calculation from the smart meter to the utility operations center.

The DLMS/COSEM protocol stack includes five OSI communication layers (illustrated in Fig. 1) and encodes the metering data in objects using the ASN.1 notation. Moreover, it allows data exchanges using both High-level Data Link Control (HDLC) [7] and Internet Protocol (IP) [8] transport layers. When the IP transport layer is used the network packets can be exchanged either through the Transmission Control Protocol (TCP) or and User Datagram Protocol (UDP). However, in most of the existing DLMS/COSEM implementations are based on TCP, as it 1) supports packet acknowledgments which is vital for notifications on the packet reception and 2)

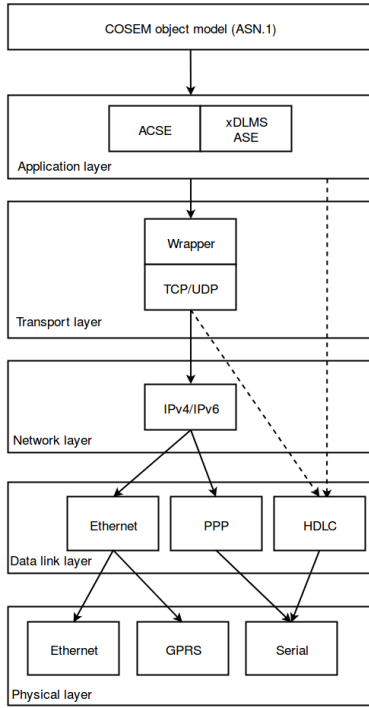


Fig. 1: DLMS/COSEM protocol stack (based on [3])

establishes an active session between the meter and the AMI Headend, to provide protection against the reception of false meter readings.

To initiate a session in DLMS/COSEM, an Application AssociationRequest (AARQ) is used. Fig. 2 presents the methods employed for message exchange in DLMS/COSEM between the COSEM Client (i.e., AMI Headend [2]) and the COSEM Server, which is the physical device as the smart meter. Moreover, DLMS/COSEM ensures security through a dedicated data protection security layer, which incorporates encryption and authentication mechanisms (Fig. 2). The encryption relies on either Elliptic Curve Digital Signature Algorithm (ECDSA) or Elliptic Curve Diffie-Hellman (ECDH) key agreement [9]. Specifically, authentication within DLMS/COSEM involves three distinct procedures:

- 1) No Security: No authentication occurs.
- 2) Low-Level Security (LLS): The DLMS server authenticates the DLMS client using a password.
- 3) High-Level Security (HLS): Entails mutual identification between both the DLMS client and server through a challenge exchange and subsequent verification of the challenge result.

B. Integration within 5G network slices

ETSI TS 122 261 standard [4] specifies the service requirements for the integration of the AMI infrastructure with 5G systems. Smart meters may interact through both cellular as well as Ethernet/fiber optic interfaces (illustrated in Fig. 3), however the two connectivity interfaces do not operate simultaneously. The cellular interface uses commercial SIM cards providing 5G connectivity (Standalone in Fig. 3), which ensures low latency and resource consumption as well as availability in distant and harsh locations (e.g. underground buildings). An alternative connectivity interface is based on an optical fiber and follows the Fiber-to-the-Home (FTTH) [10] architecture (Optical in Fig. 3). In this setup, in both communication ends (smart meter and Utility Cloud) the optical fiber signals are converted through fiber switch equipment to Ethernet cables that are connected to the infrastructure equipment. A MEC

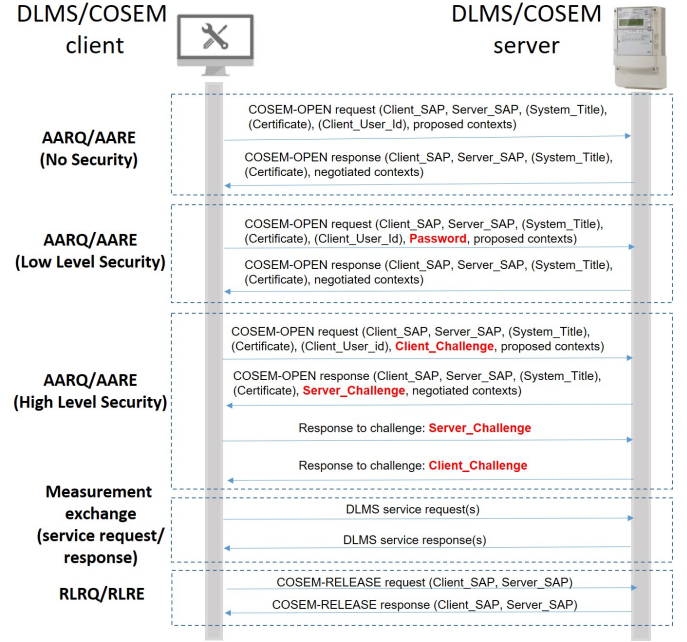


Fig. 2: AMI Headend (DLMS client) and smart meter (DLMS server) authentication mechanisms (based on [3])

host is placed on near base stations to receive, analyze the data and predict load demand peaks, which are communicated in the utility Cloud through a virtualized infrastructure that includes a Virtualized Infrastructure Manager and a Mobile Edge Orchestrator according to ETSI GS MEC 003 [11]. Moreover, an AMI Headend as well as an operator panel is installed in the Utility Cloud, where also an ETSI Open Source MANO (OSM) instance¹ is deployed to manage and instantiate the network slices.

However, the integration of DLMS-COSEM smart meter in 5G-enabled network slices inherits the cyber-security threats of a shared Network Functions Virtualization infrastructure [5]. These threats are dynamic due to the multi-tenancy of the infrastructure as well as the different network segments and technologies that are involved. To cope with this challenge, security analysts and utility personnel should first identify the risks, prioritize them and employ detection/mitigation actions tailored to them as detailed in Section III.

III. PROPOSED RISK ASSESSMENT METHOD

A comprehensive approach to assessing the risks associated with AMI systems should encompass several key components. These components should involve evaluating system dependability, conducting a thorough assessment of threats and vulnerabilities, and analyzing inter-dependencies within the system. Additionally, it is essential to incorporate a stakeholder analysis into this methodology to account for their perspectives, assumptions, and expectations. Considering this, our method is divided in main three phases 1) risk identification, 2) risk analysis and 3) risk evaluation. These phases are illustrated in Fig. 4.

In the first phase, risk identification aims at identifying potential risks that could affect the AMI system. It is the first step in the risk management process and involves identifying events or circumstances that could have a negative impact on the achievement of project objectives. Then risk analysis identifies the main factors used for risk computation, which

¹<https://osm.etsi.org/>

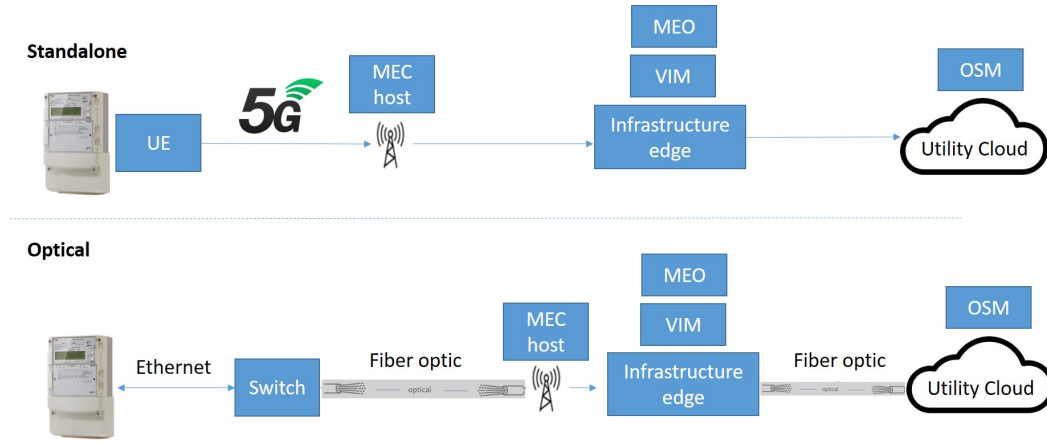


Fig. 3: Smart meter architectural deployment

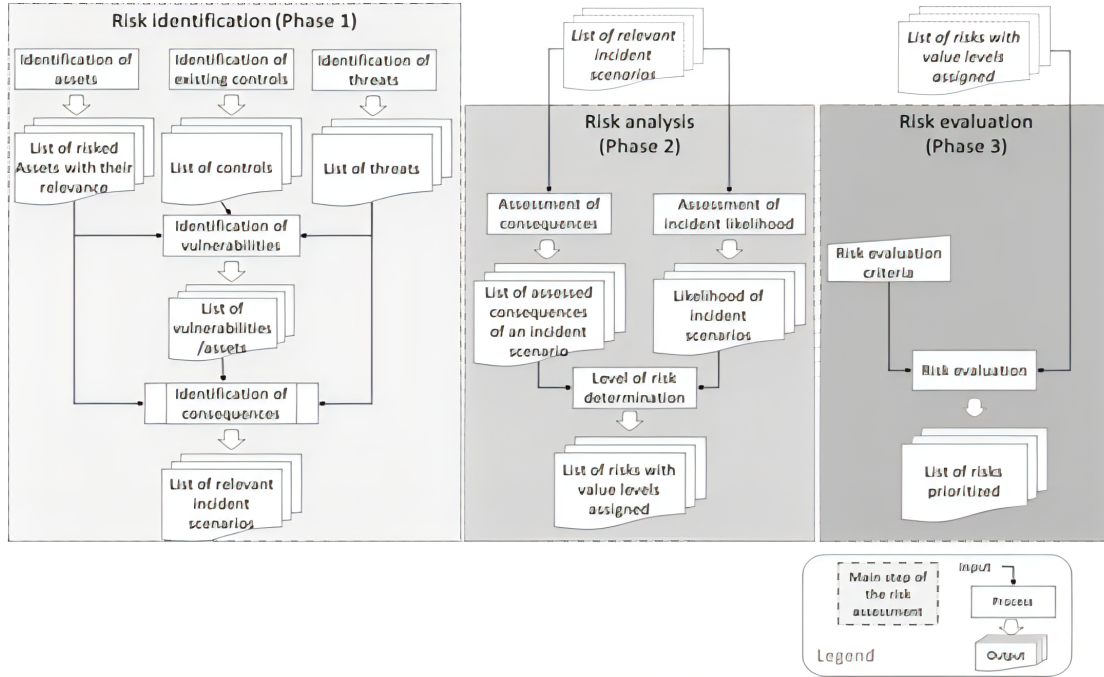


Fig. 4: Risk assessment methodology

usually are 1) Impact, indicating what is the outcome from the occurrence of a certain threat and 2) Likelihood, indicating how likely is a certain threat to occur.

Risk analysis is the most important step because it provides a systematic approach to identifying and evaluating risks, which helps organizations make informed decisions about how to manage risks in a cost-effective and efficient manner. The last step involves risk evaluation which aims at gauging the significance of identified risks by comparing the outcomes of risk analysis with established risk criteria. It involves evaluating the risks in terms of their potential impact on the project or organization, as well as the likelihood of their occurrence.

Based on ISO27001 [12], once these two factors are determined then the risk can be computed as: Risk = Impact x Likelihood. In turn, Likelihood = Threat x Vulnerability. Moreover, NIST SP 800-30 [6] categorizes risk according to a matrix illustrated in Fig. 5 that determines the threat severity based on the ease of access along with impact. The matrix categorizes items into five distinct groups:

- 1) "Normal" signifies a state with no associated risk.
- 2) "Low" represents a situation with minimal risk.
- 3) "Medium" denotes a level of risk that is considered

adequate.

- 4) "High" indicates a substantial and severe threat to the system.
- 5) "Critical" is the classification denoting the most severe level of risk, demanding immediate and urgent attention and intervention.

In industrial and AMI systems, particular emphasis is typically placed on addressing issues classified as "Critical" or "High risk," as these demand immediate attention and priority when it comes to remedial actions.

IMPACT	High	Medium	High	Critical
	Medium	Medium	Medium	High
	Low	Low	Low	Medium
EASE-OF-ACCESS X IMPACT = SEVERITY		Low	Medium	High
		EASE-OF-ACCESS		

Fig. 5: Risk Matrix

In order to assess the factors contributing to the risk assessment procedure, the next sections focus on explaining

the impact and likelihood as well as provide insights on how they are linked to the AMI system.

A. Impact Analysis

When establishing the risk impact definition, the initial step involves categorizing the different types of assets with connectivity interfaces. The AMI architecture is also connected to legacy assets of the traditional grid architecture, including components as Programmable Logic Controllers (PLCs), Supervisory Control And Data Acquisition (SCADA) and Remote Terminal Units (RTUs). The availability of smart meters and 5G connectivity, provides a high level of automation on the grid and real-time availability for the exchanged data, however it also increases the overall risk considerably due to the exposed connectivity interfaces. According to literature [13], even though the current number of legacy assets in the grid assets is higher than the new assets in the architecture, the legacy assets are continuously updated to comply with the requirements of the smart grid services [4], such as the need for reliable smart meter data exchange for calculating/forecasting energy demand.

Nevertheless, it's worth noting that the potential impact associated with each of both the legacy and the newly introduced AMI architecture assets may be considerably higher, potentially on par with the impact that a substantial number of AMI assets can collectively exert (for instance, a network of smart meters). This distinction arises from the fact that conventional grid assets as SCADA and RTUs exercise control over the fundamental grid functions, while AMI assets primarily serve the role of providing measurements to support these functions. Hence, the conventional assets become priority targets necessitating distinct protection measures. An initial and vital step towards analysing the impact of a certain asset is their classification according to the system they belong to (i.e. transmission, distribution, generation and consumption) as well as the following criteria:

- *Asset location*: The impact of an asset failure depends on its location, which could in turn, have the potential to trigger international, national, or regional power outages, as well as inflict harm on critical infrastructure.
- *Energy market contribution*: Specifies the impact that an asset failure causes to the energy market participants.
- *Operational impact*: The influence of assets on the operational and maintenance processes within the energy grid.
- *Consumer privacy issues*: The possibility of personal data exposure for the consumers when the asset is compromised to the personal data of citizens (i.e. privacy).
- *Consumer safety issues*: The impact that an asset failure causes to the safety for the consumption system.

Apart from the individual assets one should consider also the overall criticality of the network where they belong to. This is determined by several factors that include (but are not limited to):

- *Downtime impact*:
 - *Manufacturing cost*: This is related to the cost for the incident. The loss expectancy is calculated with the recovery cost, incident response and loss benefit due to the incident. In turn, the recovery cost is calculated with: number of people who work on handling the incident * personnel expenses * days. The incident response cost is calculated with: number of people who work on recovering the system * personnel expenses *

days + equipment (hardware and software) cost. The loss benefit is calculated with: estimated annual sales / 365 * business suspension days.

- *Safety*: Measuring the risk impact requires an estimation of the risk to the operational safety (i.e. human personnel who is on- and off-site. Additionally, we have to consider the environmental safety that is determined by a damage estimation over a certain area.
- *Associated networks*: A failure in a certain network segment may cause a substantial impact on the other networks with which the particular segment is exchanging information.
- *Incident mitigation*:
 - *Network complexity*: The overall time and effort spent in order to mitigate an incident that is caused by a threat in the network depends on the network complexity in terms of architecture as well as the communicating devices.
 - *Average device criticality*: This is a measure that considers the number of network assets and their individual criticality and computes an average that is used as an estimation of the overall criticality.
 - *Overall effort for system restoration*: This factor is related to the incident mitigation measures that are in place for the AMI system, such as the availability of an incident response (IR) team and/or prevention measures to eliminate detected AMI threats.

B. Likelihood Estimation

Likelihood is a factor specific to the AMI system that is considered. It changes dynamically according to the environment and the data that are monitored, whereas the impact that depends on generic characteristics of the asset and hence changes less frequently. In the following part we explain the main criteria that contribute to the likelihood computation. In order to pinpoint the primary determinants of likelihood, it is crucial to conduct a thorough analysis and characterization of the threats. This entails identifying the threat agents, assessing their resources, motivations, vulnerabilities, and related factors. This comprehensive examination provides a clear understanding of the probability and potential impact on various critical assets. Furthermore, this process aids in establishing the necessary measures to effectively mitigate the overall risks. The categories of AMI system threats are: 1) hazards that pose a threat to the secrecy, accessibility, and integrity of system data, 2) dangers that undermine the overall infrastructure's ability to withstand challenges, its security, and proper functioning, 3) risks associated with the operational environment within AMI operations, and 4) risks arising from inter-organizational associations and connections.

The likelihood for each threat that belongs in these categories is determined by the possibility of each cyber-threat actor type to exploit AMI vulnerabilities and its motivation as well as the availability of means to do so. AMI vulnerabilities are associated with the legacy or newly introduced assets and existing or novel Common Vulnerabilities and Exposures (CVEs) that are linked to the model/firmware of an asset or the protocols that it uses to communicate.

C. Risk calculation tool

The proposed risk assessment method of Fig. 4 is accompanied with a first tool version for identifying the vulnerabilities as well as calculating the risk score. Initially, the

tool is monitoring the network to identify both the connected devices as well as the network flows including the data and commands between them. This can be performed in real-time by connecting it in the Switched Port Analyzer (SPAN) port that performs port mirroring and can build the network topology as well as underlying connections (Fig. 6). If this is not feasible also an offline functionality is available through tcpdump captures in Packet Capture (PCAP) format. Then, based on 1) the identified devices, 2) their corresponding roles (i.e., smart meters) and 3) their manufacturer (i.e., Landis + Gyr) the tool starts by initially computing the likelihood, based on Section III-B.

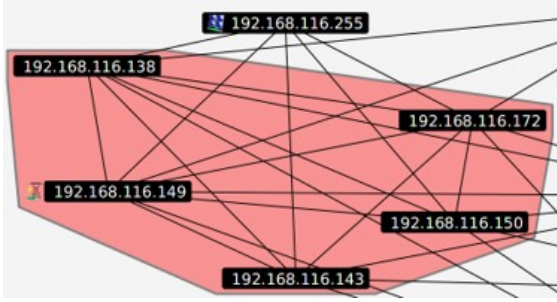


Fig. 6: Risk calculation tool network graph

The likelihood computation is based on CVE gathering from different databases including the National Vulnerability Database of NIST² as well as the CVE Program³ and CVE details of SecurityScorecard⁴. The vulnerabilities are prioritized based on a score that is computed using the Common Vulnerability Scoring System (CVSS) 3.1 standard⁵ and will be updated to comply with CVSS 4.0 as soon as it is available publicly. Then, it associates weighting factors in the likelihood and the impact. Specifically, the likelihood for each device is based on 1) the known CVEs, 2) existing connections with public IPs and 3) their proximity to any further infected or potentially vulnerable devices. Finally, the tool searches historical data or identified vulnerabilities from the device and identifies warnings of alerts that were previously identified by monitoring the network where it is deployed or the platforms that are gathering its data/diagnostics, as the AMI Headend for the smart meters. The vulnerabilities can even lie in the interfaces, software or protocols it uses as the ones identified for DLMS/COSEM in Section IV-A.

Afterwards, the tool continues by computing the impact, based on Section III-A. Impact is based on the criticality of a) the device itself and b) the network it is deployed into. As a next step, the tool also incorporates the proximity to critical devices as a impact factor. Proximity is identified based on the active connections of an AMI device i.e., smart meter with critical devices and the frequency of interactions for data or configuration exchange. Moreover, frequent interactions are highlighted in a red colored area by the tool (Fig. 6). For example if the smart meter is in a electricity production network measuring current, voltage, active and reactive power from a power generator the proximity factor value is high. Based on these factors the tool is afterwards able to compute the risk score and project it on the risk matrix of Fig. 5.

IV. DLMS/COSEM VULNERABILITIES AND MITIGATION STRATEGY

We followed the analysis of Section III, in order to analyze the DLMS/COSEM data exchange mechanisms and identify potential vulnerabilities that can be potentially exploited by adversaries, in order to plan a cyber-attack against AMI systems.

A. Identified DLMS/COSEM vulnerabilities

Even though DLMS/COSEM includes security mechanisms, the security control byte can be unset and the authentication tag (22 bytes in a message) can be removed (Fig. 7).

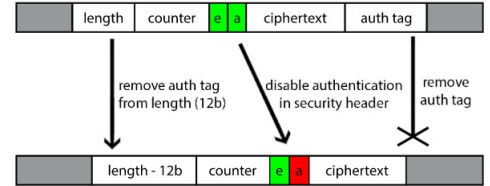


Fig. 7: DLMS/COSEM authentication operations

Initially, the DLMS/COSEM message system title consists of an 8-octet value used for meter identification. The initial 3 octets of the system title contain the manufacturer's three-letter ID (FLAG ID), while the remaining octets hold the meter's serial number. However, since the smart meter has finite memory and there are 2^{64} possible titles, a table can be filled by an attacker with arbitrary system titles, resulting in denial of service.

To identify more vulnerabilities, we have developed a client/server implementation based on the jDLMS library⁶ of the openMUC group at Fraunhofer ISE to analyze better message exchange. First, we have investigated that all smart meter manufacturers use the same password for connecting to their interface as well as often the same encryption key is used. Hence, if an adversary is able to intercept the password or the key of a smart meter, access to all other utility company's meters is possible. Furthermore, most of the services were set to be confirmed, but often no confirmation occurred. This resulted the meter to be in a non-operational state, provided in jDLMS by an error enumerator⁷.

Moreover, given the AARQ defines the context name Logical name reference (LN) that uses Get (read data) or Set (write data) commands Short name reference (SN) that uses Read and Write commands. If the correct commands are not sent, then the session has to be re-initiated. Hence, an attacker may try to forge false commands, in order to force re-initiation of the session as a mean to establish a direct connection with the smart meter. The association request is specified in Fig. 8.

Finally, DLMS/COSEM includes the disconnect control object (Fig. 9) responsible for the delivery of electrical power in households. Through this object, the smart meter controls operation methods of the output relay to which the magnetic switch is connected. This object there are seven different modes (a to h) that may be implemented by the smart meter manufacturers and may be used to remotely cut the power from customers that are not paying their electricity bills. However, it can also be exploited by attackers to conduct a mass attack that will lead in cutting the power from most of the households in a specific neighborhood.

²<https://nvd.nist.gov/>

³<https://www.cve.org/>

⁴<https://www.cvedetails.com/>

⁵<https://www.first.org/cvss/v3.1/specification-document>

⁶<https://www.openmuc.org/dlms-cosem/>

⁷DLMS_COMMAND_CONFIRMED_SERVICE_ERROR = 0x0E

```

<AssociationRequest>
  <ApplicationContextName Value="GN" />
  <InitiateRequest>
    <ProposedDlmsVersionNumber Value="06" />
    <ProposedConformance>
      <ConformanceBit Name="ParametrizedAccess" />
      <ConformanceBit Name="MultipleReferences" />
      <ConformanceBit Name="Write" />
      <ConformanceBit Name="Read" />
    </ProposedConformance>
    <ProposedMaxPduSize Value="FFFF" />
  </InitiateRequest>
</AssociationRequest>

```

Fig. 8: AARQ request

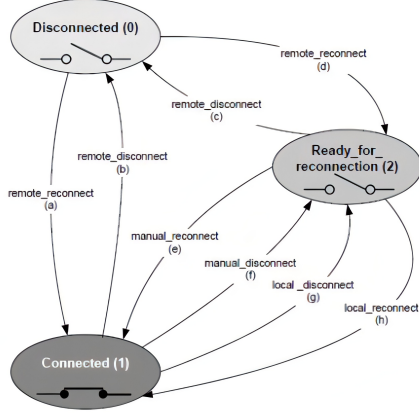


Fig. 9: Disconnect control object

B. Proposed mitigation actions

The vulnerabilities that were identified in the previous section may be exploited by adversaries to cause severe damage in the AMI infrastructure. Hence, mitigation actions shall be followed to ensure cyber-resilience for AMI systems using the DLMS/COSEM protocol.

Initially, data exchange based on DLMS/COSEM should be enriched by the TLS 1.3 protocol [14] since it provides enhanced security by stopping the support of vulnerable cryptographic algorithms that were in place till TLS 1.2. TLS 1.3 serve as the starting point for eavesdropping protection and connection attempts towards the smart meters or the Utility Cloud.

For being able to mitigate the rest of the identified vulnerabilities in Section IV-A (and maybe further ones based on the DLMS/COSEM protocol specification), security engineers should be able to detect the corresponding DLMS/COSEM message sequences and flag them as "dangerous" commands, which are of high impact and based on their likelihood, which is computed specifically for the system-under-study, they may result in low or medium level risk (Section III). Such detection can be performed through the use of a Runtime Security Monitor (Fig. 10), which is monitoring the network packets and whenever it identifies a "dangerous" command, the involved AMI components as well as any further components they interact with are placed in a separate Virtual LAN (VLAN) segment where an investigation is initiated for checking if it was linked to an operational fault or caused by a cyber-attack.

Meanwhile, hot standby devices including a smart meter should be activated to ensure the continuous system operation and electrical measurement availability. Specifically for the disconnect control object, utilities in each region (e.g., Europe, United States) use a different default mode when deploying the meters and usually not all modes are implemented. Further-

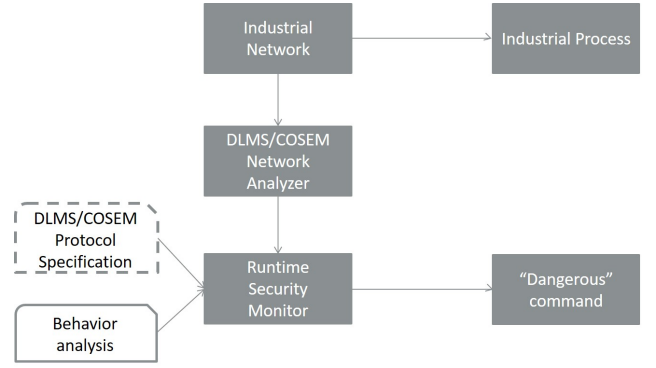


Fig. 10: Runtime Security Monitor for detection/mitigation of DLMS/COSEM vulnerabilities

more, implementation also depends on regulations in for example remotely cutting off power from a household. Therefore, the Runtime Security Monitor should learn the operational mode for each DLMS/COSEM protocol implementation (i.e., behavior analysis in Fig. 10) before detection is initiated.

V. PROOF-OF-CONCEPT: 5G-ENABLED SMART HOME AREA NETWORK TESTBED

The testbed that was used for conducting the experiments for the risk assessment method was built on the Public Power Corporation (PPC) Innovation Hub premises⁸ and serves as a smart home area network environment for conducting energy efficiency and cyber-attack scenarios. It encompasses several components, including solar PV plants, temperature and humidity sensors, an Electric Vehicle (EV) charger, Lithium Iron Phosphate batteries with a Battery Management System (BMS), and Direct Current/Alternate Current (DC/AC) inverters for energy storage. The BMS system plays a crucial role in maintaining energy balance, ensuring that battery energy is not excessively depleted. Furthermore, the batteries not only store energy but also enable real-time usage, particularly when solar energy from the PV panels is available. The smart meter is employed to measure energy consumption and create resident-specific usage profiles and its infrastructure setup is based on the Optical deployment of Fig. 3. Moreover, 5G connectivity (through the Standalone deployment of Fig. 3) is used as a backup solution, to ensure continuous reliability and availability of the smart meter data exchange service.

The system receives power from the electrical grid and a Home PV system. Additionally, it incorporates a PLC for diagnostics, fault detection and for building the battery storage profiles that are afterwards provided to the BMS. Moreover, the smart meters are manufactured by Landis+Gyr and are based on the E650 model⁹. Moreover, the E650 model compatible with 5G connectivity as well as DLMS/COSEM. Finally, the AMI Headend that is used is based on the GuruX library¹⁰, monitoring the exchanged network packets. The architectural layout of the emulated testbed is depicted in Fig. 11.

We have conducted a set of cyber-attacks by leveraging the vulnerabilities of the DLMS/COSEM protocol that were described in Section IV. An interesting attack of this set was the Address Resolution Protocol (ARP) spoofing, where we managed to intercept the AARQ request that is sent between the smart meter and GuruX through the Ettercap software [15]. Moreover, since the communication is based on long-lasting TCP sessions [16], by conducting ARP spoofing attackers may

⁸<https://innovationhub.dei.gr/en/>

⁹<https://www.landisgyr.eu/product/landisgyr-e650/>

¹⁰<https://github.com/Gurux/Gurux.DLMS.UI.Net>

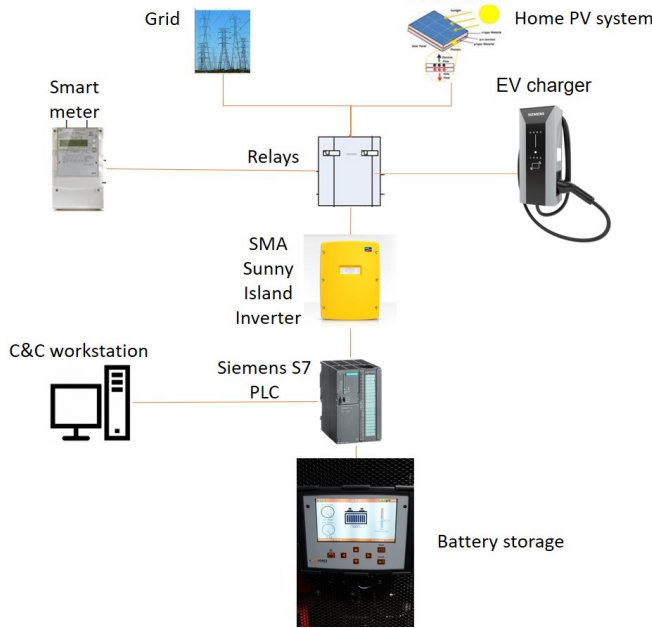


Fig. 11: Smart home area network testbed

intercept the entire active session between the meter and the AMI Headend. Moreover, after the successful vulnerability exploitation, the attack uses lateral movement techniques for connecting to the rest of the network devices.

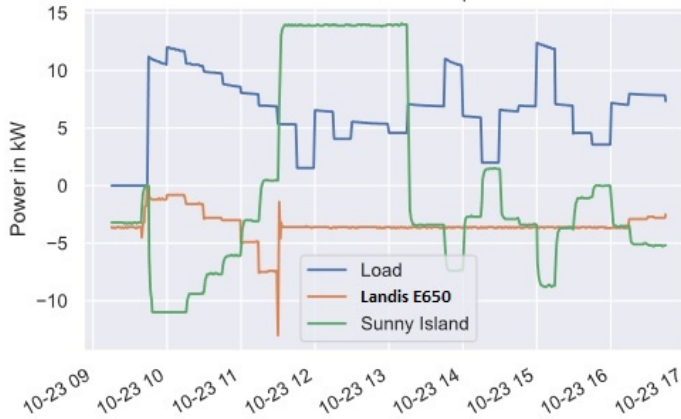


Fig. 12: Attack scenario in the smart home network

Fig. 12 presents the overall energy load from the PV and energy storage battery. The illustrated measurements are captured starting at 9:15 am (real-world time) and the attack begins at 11:30 am. The duration of the attack is 1h 45min and therefore ends at 02:15 pm. Moreover, the attack goal is to set a power limitation for inverter and the maximum charging power for the battery (illustrated in Fig. 12). Specifically, the battery management starts working in a proper way after the attack scenario ends. This leads to imbalanced energy flow, which causes fluctuations in the system and hence damages to the individual devices. In turn, the damages have as a direct consequence the blackout of the smart home as well as the devices to a substantial effort and budget to repair or replace the individual devices.

VI. CONCLUSION

This paper presents a risk assessment method for AMI systems using the DLMS/COSEM protocol for smart meter data exchange. The method identifies the vulnerabilities of DLMS/COSEM communication and assesses their impact on the AMI system. It also introduces a risk matrix to identify

their severity and prioritize their resolution. A proof-of-concept method application is demonstrated in a 5G-enabled smart home network for conducting ARP spoofing and then causing fluctuations of the energy storage battery and the PV system that lead to device damage and blackout for the household.

As part of our current work, we are developing detection mechanisms for the presented attacks that are exploiting the discovered DLMS/COSEM vulnerabilities as well as include mitigation strategies for the DLMS/COSEM vulnerabilities that were identified. The detection mechanisms are based on the DLMS/COSEM protocol analyzer, which receives network packets, parses their ASN.1 notation and detection anomalies at the network as well as the electrical measurement level. Further security mechanisms will be also investigated to ensure network slice isolation [17] for AMI applications.

ACKNOWLEDGMENT

This work has been supported by EU Project OPTI-MAI (H2020-NMBP-TR-IND-2020-singlestage, Topic: DT-FOF-11-2020, GA 958264). The authors acknowledge this support. Additionally, this work was also partially funded by the European Union's Horizon Research and Innovation Programme under grant agreement No 101070586 (PHOENIX).

REFERENCES

- [1] Mohassel, Ramyar Rashed et. al, "A survey on advanced metering infrastructure," *International Journal of Electrical Power & Energy Systems*, vol. 63, pp. 473–484, 2014.
- [2] Sarfi, Robert et. al, "Ami network (ami head-end to/from smart meters)," *Onramp Wireless, San Diego, CA, USA, Tech. Rep.*, 2012.
- [3] Sari, Alparslan et. al, "Industrial networks and iiot: Now and future trends," *Industrial IoT: Challenges, Design Principles, Applications, and Security*, pp. 3–55, 2020.
- [4] ETSI, "Ts 122 261, service requirements for the 5g system," version 16.14.0 Release 16.
- [5] Jorquera Valero, José María et. al, "Design of a security and trust framework for 5g multi-domain scenarios," *Journal of Network and Systems Management*, vol. 30, no. 1, p. 7, 2022.
- [6] Al Fikri, Muhamad et. al, "Risk assessment using nist sp 800-30 revision 1 and iso 27005 combination technique in profit-based organization: Case study of zzz information system application in abc agency," *Procedia Computer Science*, vol. 161, pp. 1206–1215, 2019.
- [7] International Electrotechnical Commission, "Electricity metering - Data exchange for meter reading, tariff and load control," *IEC-62056 Part 46*, vol. 21, pp. 31–51, 2002.
- [8] International Electrotechnical Commission, "Electricity metering data exchange - The DLMS/COSEM suite-Part 5-3: DLMS/COSEM application layer," *IEC 62056-5-3: 2016*, ed, Tech. Rep., 2016.
- [9] DLMS User Association, "Dlms/cosem architecture and protocols," *Green Book*, 2019.
- [10] T. Koonen, "Fiber to the home/fiber to the premises: what, where, and when?" *Proceedings of the IEEE*, vol. 94, no. 5, pp. 911–934, 2006.
- [11] ETSI, "Gs mec 003: Multi-access edge computing (mec); framework and reference architecture," version V3.1.1, 2022.
- [12] A. Calder and S. G. Watkins, *Information security risk management for ISO27001/ISO27002*. It Governance Ltd, 2010.
- [13] W. Wang and Z. Lu, "Cyber security in the smart grid: Survey and challenges," *Computer networks*, vol. 57, no. 5, pp. 1344–1371, 2013.
- [14] Dowling, Benjamin et. al, "A cryptographic analysis of the tls 1.3 handshake protocol," *Journal of Cryptology*, vol. 34, no. 4, p. 37, 2021.
- [15] D. Norton, "An ettercap primer," *SANS Institute InfoSec Reading Room*, vol. 5, 2004.
- [16] Tudor, Valentin et al., "Harnessing the unknown in advanced metering infrastructure traffic," in *30th Annual ACM Symp. on Appl. Comp.*, 2015.
- [17] Gonzalez, Andres J et. al, "The isolation concept in the 5g network slicing," in *2020 European Conference on Networks and Communications (EuCNC)*. IEEE, 2020, pp. 12–16.